

Sprint 4 – Estudo de Caso: Auditoria em Sistema de Prontuário Eletrônico Hospitalar

Cenário

O Hospital Casa de Saúde Braisl utiliza um sistema de prontuário eletrônico para armazenar:

- Nome dos pacientes
- CPF
- Histórico médico
- Exames laboratoriais
- Prescrições médicas
- Laudos

Recentemente ocorreram suspeitas de:

- Acesso indevido a prontuários
- Falta de backups
- Compartilhamento inadequado de dados
- Falhas de rastreabilidade

A direção do hospital contratou uma equipe de auditoria para avaliar a conformidade do sistema.

Objetivo da Auditoria

Verificar se o sistema:

- Protege os dados dos pacientes
- Atende aos requisitos da LGPD
- Possui controles de acesso adequados
- Mantém registros de auditoria
- Possui mecanismos de recuperação de desastres

Escopo da Auditoria

Módulos auditados

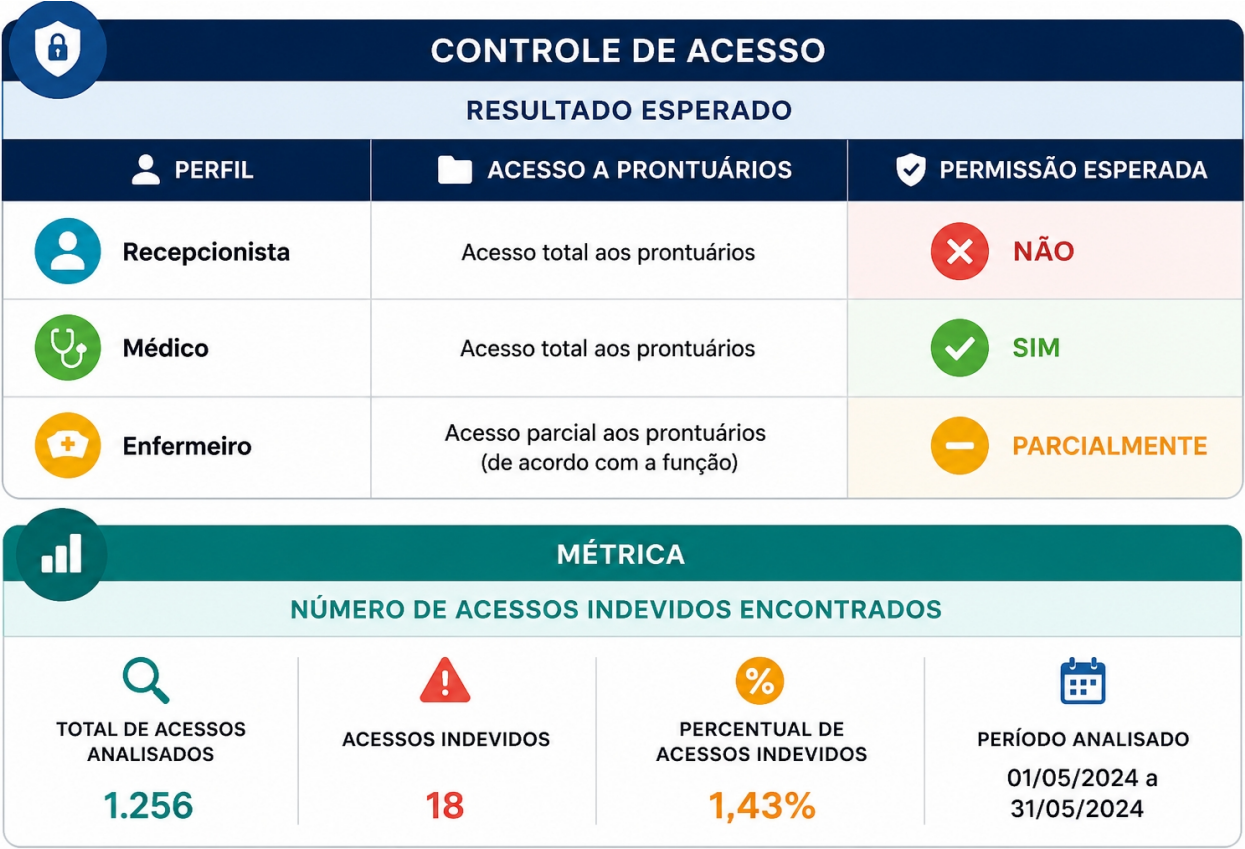
- Login
- Cadastro de pacientes
- Prontuários
- Exames
- Relatórios
- Banco de dados

Itens Auditados

1. Controle de Acesso

Pergunta:

Um recepcionista consegue visualizar exames médicos?



2. Logs de Auditoria

TRILHAS DE AUDITORIA

VERIFICAR SE O SISTEMA REGISTRA:

QUEM ACESSOU

QUANDO ACESSOU

QUAL PRONTUÁRIO ACESSOU

QUAL ALTERAÇÃO REALIZOU

EXEMPLO DE REGISTROS

USUÁRIO	DATA	PRONTUÁRIO ACESSADO	AÇÃO REALIZADA
JS João	10/06/2024 08:42:15	Prontuário #12345 Paciente: Ana Silva	Consulta
MJ Maria	10/06/2024 09:17:33	Prontuário #67890 Paciente: Carlos Souza	Alteração
EF Enfermeiro Felipe	10/06/2024 10:03:50	Prontuário #12345 Paciente: Ana Silva	Visualização Parcial

3. Backup

3. BACKUP

VERIFICAR:

FREQUÊNCIA

LOCAL DE ARMAZENAMENTO

TESTES DE RESTAURAÇÃO

RECUPERAÇÃO DOS DADOS

MÉTRICA

TEMPO DE RECUPERAÇÃO (RTO)
RECOVERY TIME OBJECTIVE –
objetivo do tempo de recuperação

RTO DEFINIDO
30 minutos

EXEMPLO

CENÁRIO	EVENTO	RTO DEFINIDO	RESULTADO ESPERADO
Hospital – Sistema de Prontuário Eletrônico	Prontuário para às 10h00	30 minutos	Sistema deve estar funcionando novamente até 10h30

4. Segurança das Senhas

Critérios:

- Mínimo de 8 caracteres
- Letras maiúsculas
- Números
- Caracteres especiais

Métrica: Percentual de contas em conformidade

5. LGPD

Verificar:

- Consentimento dos pacientes
- Política de privacidade
- Tratamento de dados sensíveis

Métrica: Número de não conformidades LGPD

Achados da Auditoria

ACHADOS DA AUDITORIA				
NÃO CONFORMIDADE	RISCO	RECOMENDAÇÃO	IMPACTO	PRIORIDADE
1 NÃO CONFORMIDADE 1 Recepcionistas conseguem visualizar exames médicos.	 RISCO Violação da confidencialidade.	 RECOMENDAÇÃO Implementar RBAC (Controle de Acesso Baseado em Funções).	 IMPACTO Alto Alto impacto em dados sensíveis	 PRIORIDADE ALTA
2 NÃO CONFORMIDADE 2 Backups são realizados apenas uma vez por mês.	 RISCO Perda de dados.	 RECOMENDAÇÃO Realizar backup diário e armazenar em local seguro e redundante.	 IMPACTO Alto Pode causar perda de informações críticas	 PRIORIDADE ALTA
3 NÃO CONFORMIDADE 3 Sistema não utiliza MFA.	 RISCO Acesso indevido.	 RECOMENDAÇÃO Implementar MFA (Autenticação de dois fatores).	 IMPACTO Alto Aumenta o risco de acessos não autorizados	 PRIORIDADE ALTA
 NOTA: As não conformidades identificadas representam riscos significativos à segurança da informação e à conformidade regulatória (LGPD, normas de sigilo médico e boas práticas de TI).				

Métricas complementares importantes

Taxa de Conformidade

INDICADORES DE SEGURANÇA DA INFORMAÇÃO		
INDICADOR	DEFINIÇÃO / FÓRMULA	EXEMPLO / VALOR
 Taxa de Conformidade	Fórmula: (Total de requisitos atendidos / Total de requisitos avaliados) × 100	Exemplo: 18 / 25 = 72% 72%
 Índice de Vulnerabilidades	● Críticas = 2 ● Altas = 4 ● Médias = 3 ● Baixas = 5	Críticas 2 Altas 4 Médias 3 Baixas 5
 Tempo Médio de Recuperação	MTTR = Mean Time To Recovery	Exemplo: 45 minutos 45 min